

Entrega 1: Relatório de Vulnerabilidades do Sistema e do Código (Smart Tennis Arena)

Disciplina: Redes de Computadores e Cibersegurança

Equipe: GRUPO 5 - CCOMP 6

- Lucas Oliveira
- Matheus Rossaneze
- Pedro Schaurich Maia
- Phelipe Antonio

1. Visão Geral da Arquitetura e Escopo da Avaliação
2. Metodologia e Ferramentas de Análise (SAST e DAST)
3. Matriz de Vulnerabilidades Identificadas
4. Evidências dos Scans (Print Screens ou Logs)
5. Código com Segurança Aplicada (Mitigações)
6. Conclusão

1. Visão Geral da Arquitetura e Escopo da Avaliação

O projeto visa o desenvolvimento de uma solução integrada de IoT e Robótica para a criação e execução de treinos gamificados de tênis. A arquitetura da solução é composta por um Aplicativo Mobile, um Servidor Local (Backend/API) e um hardware construído com Arduino.

A comunicação do ecossistema opera em duas frentes:

1. Mobile ↔ Servidor Local: O aplicativo se comunica com a API (Backend) por meio da rede local.
2. Servidor Local ↔ Arduino: A comunicação com o microcontrolador ocorre exclusivamente via cabo (Serial/USB). Diferente de projetos convencionais IoT, não há interface de rede sem fio (Wi-Fi/Bluetooth) acoplada diretamente ao circuito do Arduino.

Nesse contexto, o escopo desta avaliação focou em proteger a API contra injeções e ataques originados no lado do cliente, além de realizar a blindagem (*hardening*) crítica da interface de comunicação Serial.

2. Metodologia e Ferramentas de Análise (SAST e SCA)

Nossa metodologia priorizou a segurança estrutural do código e das dependências, baseando-se em Análise Estática (SAST) e Análise de Composição de Software (SCA).

As ferramentas executadas foram:

- **Servidor e Mobile (TypeScript/Node):** Utilizamos a CLI do **Snyk** (snyk code test, snyk test) e o **npm audit** para buscar vulnerabilidades lógicas, credenciais expostas (*hardcoded secrets*), injeções e falhas nas bibliotecas de terceiros listadas no package.json.
- **Firmware Arduino (C/C++):** Aplicamos o analisador estático open-source **Cppcheck** diretamente nos arquivos do projeto embarcado. O objetivo principal foi interceptar problemas de gerenciamento de memória, como potenciais *buffer overflows* na leitura de dados pela Serial.

3. Matriz de Vulnerabilidades Identificadas

Os testes estáticos (Snyk Code) não apontaram nenhuma vulnerabilidade no código-fonte proprietário do aplicativo mobile, no pacote compartilhado (*shared*) ou na raiz do projeto. A auditoria de dependências no pacote *shared* também retornou zero (0) problemas.

As vulnerabilidades mapeadas abaixo referem-se estritamente às dependências de terceiros no ambiente Mobile (pacotes do Expo/Metro) e a riscos arquiteturais preventivos associados ao hardware:

ID	Camada Afetada (API, Mobile, Firmware)	Nome da Vulnerabilidade / Descrição Breve	Nível de Risco (Crítico, Alto, Médio, Baixo)	Ferramenta que Identificou	Mitigação Proposta (A ser detalhada na seção 5)
01	Mobile (Dependências)	Uncontrolled Recursion no	Alto	Snyk (SCA)	Aceitação de risco temporária (falha na

ID	Camada Afetada (API, Mobile, Firmware)	Nome da Vulnerabilidade / Descrição Breve	Nível de Risco (Crítico, Alto, Médio, Baixo)	Ferramenta que Identificou	Mitigação Proposta (A ser detalhada na seção 5)
		pacote braces@3.0.3			esteira de build do React Native/Metro, sem impacto direto na execução local do hardware).
02	Mobile (Dependências)	Prototype Pollution no pacote deepmerge@4.3.1	Alto	Snyk (SCA)	Atualização futura da dependência transitiva através de <i>patch</i> no ecossistema Expo.
03	Mobile (Dependências)	Improper Verification of Cryptographic Signature no node-forge	Alto	Snyk (SCA)	Risco mitigado pelo fato da comunicação principal do hardware ocorrer via cabo serial local, não expondo assinaturas criptográficas para a internet.
04	Mobile (Dependências)	Missing buffer bounds check no pacote uuid	Médio	npm audit / Snyk	Executar npm audit fix para atualizar o pacote uuid para a versão 11.1.1 ou superior.
05	Firmware (Arduino)	Buffer Overflow / Injeção de Comandos via porta Serial (Risco Arquitetural).	Crítico	Prevenção Arquitetural / SAST	Implementação de controle de tamanho máximo de <i>buffer</i> e interrupção prioritária (SAFE_STOP) no

ID	Camada Afetada (API, Mobile, Firmware)	Nome da Vulnerabilidade / Descrição Breve	Nível de Risco (Crítico, Alto, Médio, Baixo)	Ferramenta que Identificou	Mitigação Proposta (A ser detalhada na seção 5)
					código C++ do microcontrolador.

4. Evidências dos Scans (Print Screens ou Logs)

Evidência 1 (SAST Limpo): A execução do Snyk Code na pasta raiz do projeto obteve sucesso sem apontamentos lógicos ou de injeção ("Total issues: 0").

O que está acontecendo aqui?

O log exibe o sumário ("Test Summary") da análise estática recém-concluída no código-fonte do projeto.

Por que este comando foi executado?

O terminal está renderizando a interface da CLI do Snyk para confirmar as informações básicas da varredura, como a organização do usuário (psm301004), o tipo de teste e a pasta analisada. O principal destaque é a linha Total issues: 0, atestando que o código proprietário está livre de vulnerabilidades.

```
Testing C:\Users\psm30\Code\Projeto5\src ...

Test Summary
Organization: psm301004
Test type: Static code analysis
Project path: C:\Users\psm30\Code\Projeto5\src

Total issues: 0
```

Evidência 2 (Análise de Dependências): A varredura identificou vulnerabilidades nos pacotes de terceiros transitivos do módulo Mobile (braces, deepmerge, node-forge, uuid), mas atestou a total aprovação do módulo *Shared*.

O que está acontecendo aqui? A varredura de Composição de Software (SCA) foi direcionada especificamente para a pasta do aplicativo mobile. O log exibe a ferramenta analisando centenas de dependências e listando as vulnerabilidades encontradas (como falhas nos pacotes uuid, braces e outras bibliotecas transitivas do Expo/Metro), indicando a gravidade de cada uma e se existe atualização direta disponível.

Por que este comando foi executado? O objetivo é descobrir se o projeto importa bibliotecas de terceiros que possuam brechas de segurança públicas conhecidas (CVEs). Ter essa visibilidade nos permite tomar decisões arquiteturais e de mitigação: atualizar pacotes inseguros (como no caso do uuid) ou documentar a aceitação temporária do risco para dependências exclusivas de desenvolvimento que não afetam o ambiente local.

```
Testing C:\Users\psm30\Code\Projeto5\src\mobile...
```

```
Tested 470 dependencies for known issues, found 4 issues, 6 vulnerable paths.
```

```
Issues with no direct upgrade or patch:
```

```
  ðŸ’€ Uncontrolled Recursion [High Severity][https://security.snyk.io/vuln/SNYK-JS-BRACES-19963945] in braces@3.0.3  
    introduced by react-native@0.86.3 > @react-native/community-cli-plugin@0.86.3 > metro@0.84.5 > metro-file-map@0.84.5 >  
micromatch@4.0.8 > braces@3.0.3 and 1 other path(s)
```

```
No upgrade or patch available
```

```
  ðŸ’€ Prototype Pollution [High Severity][https://security.snyk.io/vuln/SNYK-JS-DEEPMERGE-19964053] in deepmerge@4.3.1  
    introduced by expo@57.0.24 > @expo/cli@57.0.26 > @expo/config@57.0.9 > deepmerge@4.3.1
```

```
No upgrade or patch available
```

```
  ðŸ’€ Improper Verification of Cryptographic Signature [High Severity][https://security.snyk.io/vuln/SNYK-JS-NODEFORGE-19635204] in  
node-forge@1.4.0
```

```
    introduced by expo@57.0.24 > @expo/cli@57.0.26 > node-forge@1.4.0 and 1 other path(s)
```

```
No upgrade or patch available
```

```
  ðŸ’€ Improper Validation of Specified Index, Position, or Offset in Input [Medium  
Severity][https://security.snyk.io/vuln/SNYK-JS-UUID-16133035] in uuid@7.0.3
```

```
    introduced by expo@57.0.24 > @expo/cli@57.0.26 > @expo/config@57.0.9 > @expo/config-plugins@57.0.9 > xcode@3.0.1 >  
uuid@7.0.3
```

```
This issue was fixed in versions: 11.1.1, 14.0.0
```

```
Organization:   psm301004
```

```
Package manager: npm
```

```
Target file:    package-lock.json
```

```
Project name:    mobile
```

```
Open source:     no
```

```
Project path:    C:\Users\psm30\Code\Projeto5\src\mobile
```

```
Licenses:        enabled
```

npm audit report

uuid <11.1.1

Severity: moderate

uuid: Missing buffer bounds check in v3/v5/v6 when buf is provided - <https://github.com/advisories/GHSA-w5hq-g745-h8pq>

fix available via `npm audit fix --force`

Will install expo@46.0.21, which is a breaking change

node_modules/uuid

xcode >=0.9.2

Depends on vulnerable versions of uuid

node_modules/xcode

@expo/config-plugins *

Depends on vulnerable versions of xcode

node_modules/@expo/config-plugins

@expo/cli <=0.0.0-canary-20231123-1b19f96-4 || >=0.0.1-canary-20231125-d600e44

Depends on vulnerable versions of @expo/config

Depends on vulnerable versions of @expo/config-plugins

Depends on vulnerable versions of @expo/inline-modules

Depends on vulnerable versions of @expo/metro-config

Depends on vulnerable versions of @expo/prebuild-config

node_modules/expo/node_modules/@expo/cli

expo 40.0.0-alpha.0 - 40.0.0-beta.5 || >=41.0.0-alpha.0

Depends on vulnerable versions of @expo/cli

Depends on vulnerable versions of @expo/config

Depends on vulnerable versions of @expo/config-plugins

Depends on vulnerable versions of @expo/local-build-cache-provider

Depends on vulnerable versions of @expo/metro-config

node_modules/expo

@expo/config <=0.0.1-canary-20240418-8d74597 || >=3.3.23-alpha.0

Depends on vulnerable versions of @expo/config-plugins

node_modules/@expo/config

@expo/local-build-cache-provider *

Depends on vulnerable versions of @expo/config

node_modules/@expo/local-build-cache-provider

@expo/metro-config <=0.0.1-canary-20240418-8d74597 || >=0.1.49-alpha.0

Depends on vulnerable versions of @expo/config

node_modules/@expo/metro-config

@expo/inline-modules >=0.0.2-canary-20260409-6fc2991

Depends on vulnerable versions of @expo/config-plugins

node_modules/@expo/inline-modules

@expo/prebuild-config *

Depends on vulnerable versions of @expo/config

Depends on vulnerable versions of @expo/config-plugins

node_modules/@expo/prebuild-config

10 moderate severity vulnerabilities

To address issues that do not require attention, run:

npm audit fix

To address all issues (including breaking changes), run:

npm audit fix --force

5. Código com Segurança Aplicada (Mitigações)

Para resolver as vulnerabilidades apontadas, foram aplicadas correções automáticas no gerenciamento de pacotes (SCA) combinadas com a blindagem arquitetural e validação de *payloads*.

Comando e Log de Correção (Terminal):

O que está acontecendo aqui? O terminal mostra o gerenciador de pacotes do Node (npm) aplicando correções automáticas seguras nas dependências. O resumo indica que ele alterou alguns pacotes, mas não conseguiu resolver as vulnerabilidades mais complexas sem causar mudanças drásticas na versão das bibliotecas.

Por que este comando foi executado? O comando `npm audit fix` é sempre a primeira linha de defesa. Ele foi executado para tentar atualizar automaticamente os pacotes vulneráveis do projeto para versões seguras (patches) de forma passiva, sem quebrar a compatibilidade do código existente.

```
npm audit fix
changed 6 packages, and audited 492 packages in 17s

46 packages are looking for funding
  run `npm fund` for details

# npm audit report
```

O que está acontecendo aqui? O terminal exibe um extenso registro de avisos (*warnings*) sobre pacotes descontinuados (*deprecated*) e alterações estruturais. No final, o relatório confirma que a árvore de dependências foi modificada e atualizações profundas foram forçadas no ecossistema para fechar brechas críticas.

Por que este comando foi executado? Como a correção padrão não resolveu a vulnerabilidade *Missing buffer bounds check* do pacote `uuid` (ID 04), foi necessário executar o comando com a flag `--force`. Essa ação obriga o npm a instalar atualizações de segurança mesmo que elas exijam pular versões inteiras de dependências-chave (como o próprio framework Expo), garantindo que a falha de limite de memória seja efetivamente mitigada na arquitetura.

```
npm audit fix --force
npm warn using --force Recommended protections disabled.
npm warn audit Updating expo to 46.0.21, which is a SemVer major change.
npm warn deprecated inflight@1.0.6: This module is not supported, and leaks memory. Do not use it. Check out lru-cache if you want a
good and tested way to coalesce async requests by a key value, which is much more comprehensive and powerful.
npm warn deprecated @babel/plugin-proposal-class-properties@7.18.6: This proposal has been merged to the ECMAScript standard and
thus this plugin is no longer maintained. Please use @babel/plugin-transform-class-properties instead.
npm warn deprecated @babel/plugin-proposal-nullish-coalescing-operator@7.18.6: This proposal has been merged to the ECMAScript
standard and thus this plugin is no longer maintained. Please use @babel/plugin-transform-nullish-coalescing-operator instead.
npm warn deprecated osenv@0.1.5: This package is no longer supported.
npm warn deprecated @babel/plugin-proposal-optional-catch-binding@7.18.6: This proposal has been merged to the ECMAScript
standard and thus this plugin is no longer maintained. Please use @babel/plugin-transform-optional-catch-binding instead.
npm warn deprecated @babel/plugin-proposal-optional-chaining@7.21.0: This proposal has been merged to the ECMAScript standard
and thus this plugin is no longer maintained. Please use @babel/plugin-transform-optional-chaining instead.
npm warn deprecated rimraf@3.0.2: Rimraf versions prior to v4 are no longer supported
npm warn deprecated @npmcli/move-file@1.1.2: This functionality has been moved to @npmcli/fs
npm warn deprecated rimraf@2.4.5: Rimraf versions prior to v4 are no longer supported
npm warn deprecated @babel/plugin-proposal-async-generator-functions@7.20.7: This proposal has been merged to the ECMAScript
standard and thus this plugin is no longer maintained. Please use @babel/plugin-transform-async-generator-functions instead.
npm warn deprecated @babel/plugin-proposal-object-rest-spread@7.20.7: This proposal has been merged to the ECMAScript standard
and thus this plugin is no longer maintained. Please use @babel/plugin-transform-object-rest-spread instead.
npm warn deprecated glob@6.0.4: Old versions of glob are not supported, and contain widely publicized security vulnerabilities, which
have been fixed in the current version. Please update. Support for old versions may be purchased (at exorbitant rates) by contacting
i@izs.me
npm warn deprecated sudo-prompt@9.1.1: Package no longer supported. Contact Support at https://www.npmjs.com/support for more
info.
npm warn deprecated glob@7.1.6: Old versions of glob are not supported, and contain widely publicized security vulnerabilities, which
have been fixed in the current version. Please update. Support for old versions may be purchased (at exorbitant rates) by contacting
i@izs.me
npm warn deprecated metro-react-native-babel-preset@0.72.3: Use @react-native/babel-preset instead
npm warn deprecated @xmldom/xmldom@0.7.13: this version has critical issues, please update to the latest version
npm warn deprecated uuid@3.4.0: uuid@10 and below is no longer supported. For ESM codebases, update to uuid@latest. For
CommonJS codebases, use uuid@11 (but be aware this version will likely be deprecated in 2028).
npm warn deprecated tar@6.2.1: Old versions of tar are not supported, and contain widely publicized security vulnerabilities, which have
been fixed in the current version. Please update. Support for old versions may be purchased (at exorbitant rates) by contacting i@izs.me
npm warn deprecated uuid@7.0.3: uuid@10 and below is no longer supported. For ESM codebases, update to uuid@latest. For
CommonJS codebases, use uuid@11 (but be aware this version will likely be deprecated in 2028).
npm warn deprecated uuid@8.3.2: uuid@10 and below is no longer supported. For ESM codebases, update to uuid@latest. For
CommonJS codebases, use uuid@11 (but be aware this version will likely be deprecated in 2028).
npm warn deprecated uuid@8.3.2: uuid@10 and below is no longer supported. For ESM codebases, update to uuid@latest. For
CommonJS codebases, use uuid@11 (but be aware this version will likely be deprecated in 2028).
```

added 462 packages, removed 59 packages, changed 42 packages, and audited 895 packages in 29s

130 packages are looking for funding
run `npm fund` for details

npm audit report

@xmldom/xmldom <=0.8.14

Severity: high

xmldom: XML injection via unsafe CDATA serialization allows attacker-controlled markup insertion -
<https://github.com/advisories/GHSA-wh4c-j3r5-mjhp>

xmldom: Uncontrolled recursion in XML serialization leads to DoS - <https://github.com/advisories/GHSA-2v35-w6hq-6mfw>

xmldom has XML injection through unvalidated DocumentType serialization - <https://github.com/advisories/GHSA-f6ww-3ggp-fr8h>

xmldom has XML node injection through unvalidated processing instruction serialization -
<https://github.com/advisories/GHSA-x6wf-f3px-wcqx>

xmldom has XML node injection through unvalidated comment serialization - <https://github.com/advisories/GHSA-j759-j44w-7fr8>

xmldom: XML fragment injection via invalid EntityReference.nodeName during requireWellFormed serialization -
<https://github.com/advisories/GHSA-6gmq-8vp8-gcm6>

xmldom: Element name injection via createElement() bypasses requireWellFormed - <https://github.com/advisories/GHSA-w2rr-34g9-rvrj>
xmldom: Attribute name injection via setAttribute() bypasses requireWellFormed - <https://github.com/advisories/GHSA-4w3w-2rp5-g8jm>
xmldom: Processing Instruction Target Injection Bypasses requireWellFormed - <https://github.com/advisories/GHSA-c7q8-3ch8-vqpvr>
xmldom: DocType `name` Injection Bypasses requireWellFormed - <https://github.com/advisories/GHSA-27p8-2357-5qqv>
xmldom: Parser silently accepts a not-well-formed end tag whose name is followed by a line break and trailing content - <https://github.com/advisories/GHSA-6h8r-xr42-gp59>
xmldom: Quadratic-time attribute deduplication - <https://github.com/advisories/GHSA-8344-3jmq-59r6>
xmldom: End-tag Whitespace-Trim Regex ReDoS — quadratic backtracking in the 0.8.x end-tag parser - <https://github.com/advisories/GHSA-x4fp-j954-r2f4>
xmldom: Quadratic-memory consumption - <https://github.com/advisories/GHSA-965w-775f-mr7g>
xmldom: Quadratic-time parsing via the malformed-input recovery path — `parseElementStartPart` re-scan and `normalize()` adjacent-text merge - <https://github.com/advisories/GHSA-93r5-fhx6-vmg9>
fix available via `npm audit fix --force`
Will install expo@57.0.25, which is a breaking change
node_modules/@xmldom/xmldom
 @expo/plist <=0.0.1-canary-20240418-8d74597 || 0.0.14 - 0.2.2
 Depends on vulnerable versions of @xmldom/xmldom
 node_modules/@expo/plist
 @expo/cli <=0.0.0-canary-20231123-1b19f96-4 || 0.0.1-canary-20231125-d600e44 - 0.23.0-canary-20250122-166c2cb || 1.0.0-canary-20240927-ab8a962 - 1.0.0-canary-20250305-0af9ad2
 Depends on vulnerable versions of @expo/config
 Depends on vulnerable versions of @expo/config-plugins
 Depends on vulnerable versions of @expo/dev-server
 Depends on vulnerable versions of @expo/metro-config
 Depends on vulnerable versions of @expo/plist
 Depends on vulnerable versions of @expo/prebuild-config
 Depends on vulnerable versions of @expo/rudder-sdk-node
 Depends on vulnerable versions of cacache
 Depends on vulnerable versions of send
 Depends on vulnerable versions of tar
 Depends on vulnerable versions of uuid
 node_modules/@expo/cli
 expo <=52.0.4
 Depends on vulnerable versions of @expo/cli
 Depends on vulnerable versions of expo-asset
 Depends on vulnerable versions of expo-constants
 Depends on vulnerable versions of expo-file-system
 Depends on vulnerable versions of uuid
 node_modules/expo
 @expo/config-plugins *
 Depends on vulnerable versions of @expo/plist
 Depends on vulnerable versions of xcode
 Depends on vulnerable versions of xml2js
 node_modules/@expo/config-plugins
 @expo/config 3.3.23-alpha.0 - 8.1.0 || 11.0.6-canary-20250428-4156f88
 Depends on vulnerable versions of @expo/config-plugins
 Depends on vulnerable versions of semver
 node_modules/@expo/config
 node_modules/@expo/metro-config/node_modules/@expo/config
 @expo/metro-config 0.1.49-alpha.0 - 0.9.0
 Depends on vulnerable versions of @expo/config
 node_modules/@expo/metro-config
 @expo/dev-server *
 Depends on vulnerable versions of @expo/bunyan
 Depends on vulnerable versions of @expo/metro-config
 Depends on vulnerable versions of body-parser
 Depends on vulnerable versions of semver
 node_modules/@expo/dev-server
 @expo/prebuild-config <=7.0.0-beta.0
 Depends on vulnerable versions of @expo/config

Depends on vulnerable versions of @expo/config-plugins
Depends on vulnerable versions of @expo/image-utils
Depends on vulnerable versions of semver
Depends on vulnerable versions of xml2js
node_modules/@expo/prebuild-config
expo-constants <=0.0.1-canary-20240418-8d74597 || 2.0.0-rc.0 - 2.0.1 || 9.1.0 - 15.4.0 || 18.1.0-canary-20251031-b135dff - 18.1.0-canary-20260113-4879b86
Depends on vulnerable versions of @expo/config
Depends on vulnerable versions of uuid
node_modules/expo-constants
expo-asset <=0.0.1-canary-20240418-8d74597 || 2.0.0-rc.0 - 2.1.0-alpha.7 || 8.6.1 - 8.14.0
Depends on vulnerable versions of expo-constants
Depends on vulnerable versions of expo-file-system
node_modules/expo-asset
expo-file-system <=0.0.1-canary-20240418-8d74597 || 8.1.0 - 16.0.0
Depends on vulnerable versions of @expo/config-plugins
Depends on vulnerable versions of uuid
node_modules/expo-file-system

body-parser <=1.20.5
Severity: high
body-parser vulnerable to denial of service when url encoding is enabled - <https://github.com/advisories/GHSA-qwcr-r2fm-qrc7>
body-parser vulnerable to denial of service when invalid limit value silently disables size enforcement - <https://github.com/advisories/GHSA-v422-hmwv-36x6>
Depends on vulnerable versions of qs
fix available via `npm audit fix`
node_modules/body-parser

qs <=6.15.3
Severity: high
qs vulnerable to Prototype Pollution - <https://github.com/advisories/GHSA-hrpp-h998-j3pp>
qs's arrayLimit bypass in comma parsing allows denial of service - <https://github.com/advisories/GHSA-w7fw-mjwx-w883>
qs's arrayLimit bypass in its bracket notation allows DoS via memory exhaustion - <https://github.com/advisories/GHSA-6rw7-vpxm-498p>
qs: Denial of Service via Attacker Controlled isBuffer - <https://github.com/advisories/GHSA-4mjr-xmp4-gh2g>
fix available via `npm audit fix`
node_modules/qs

semver 7.0.0 - 7.5.1
Severity: high
semver vulnerable to Regular Expression Denial of Service - <https://github.com/advisories/GHSA-c2qf-rxjj-qqgw>
fix available via `npm audit fix --force`
Will install expo@57.0.25, which is a breaking change
node_modules/@expo/config/node_modules/semver
node_modules/@expo/dev-server/node_modules/semver
node_modules/@expo/image-utils/node_modules/semver
node_modules/@expo/metro-config/node_modules/semver
node_modules/@expo/prebuild-config/node_modules/semver
@expo/image-utils <=0.0.1-canary-20240109-93608d8 || 0.3.10-alpha.0 - 0.4.2
Depends on vulnerable versions of semver
node_modules/@expo/image-utils

send <0.19.0
send vulnerable to template injection that can lead to XSS - <https://github.com/advisories/GHSA-m6fv-jmcg-4jfg>
fix available via `npm audit fix --force`
Will install expo@57.0.25, which is a breaking change
node_modules/@expo/cli/node_modules/send

tar <=7.5.20
Severity: critical

node-tar Vulnerable to Arbitrary File Creation/Overwrite via Hardlink Path Traversal - <https://github.com/advisories/GHSA-34x7-hfp2-rc4v>
node-tar is Vulnerable to Arbitrary File Overwrite and Symlink Poisoning via Insufficient Path Sanitization - <https://github.com/advisories/GHSA-8qq5-rm4j-mr97>
Arbitrary File Read/Write via Hardlink Target Escape Through Symlink Chain in node-tar Extraction - <https://github.com/advisories/GHSA-83g3-92jg-28cx>
tar has Hardlink Path Traversal via Drive-Relative Linkpath - <https://github.com/advisories/GHSA-qffp-2rhf-9h96>
node-tar Symlink Path Traversal via Drive-Relative Linkpath - <https://github.com/advisories/GHSA-9ppj-qmqm-q256>
Race Condition in node-tar Path Reservations via Unicode Ligature Collisions on macOS APFS - <https://github.com/advisories/GHSA-r6q2-hw4h-h46w>
node-tar applies PAX size override to intermediary GNU long-name/long-link headers, causing tar parser interpretation differential (file smuggling) - <https://github.com/advisories/GHSA-vmf3-w455-68vh>
node-tar: Process crash via PAX numeric path type confusion - <https://github.com/advisories/GHSA-w8wr-v893-vjvp>
node-tar: Decompression/parse DoS via unlimited input - <https://github.com/advisories/GHSA-23hp-3jrh-7fpw>
node-tar: Negative tar entry size causes infinite loop in archive replace - <https://github.com/advisories/GHSA-8x88-c5mf-7j5w>
node-tar: Uncaught Exception DoS via NUL byte in PAX path/linkpath records - <https://github.com/advisories/GHSA-gvwx-54wh-qm9j>
node-tar: Uncontrolled recursion in mapHas/filesFilter allows uncatchable stack-overflow DoS via crafted long-path tar with member selection - <https://github.com/advisories/GHSA-r292-9mhp-454m>
fix available via `npm audit fix --force`
Will install expo@57.0.25, which is a breaking change
node_modules/tar
cacache 14.0.0 - 18.0.4
Depends on vulnerable versions of tar
node_modules/cacache

uuid <11.1.1
Severity: moderate
uuid: Missing buffer bounds check in v3/v5/v6 when buf is provided - <https://github.com/advisories/GHSA-w5hq-g745-h8pq>
fix available via `npm audit fix --force`
Will install expo@57.0.25, which is a breaking change
node_modules/@expo/bunyan/node_modules/uuid
node_modules/@expo/rudder-sdk-node/node_modules/uuid
node_modules/uuid
node_modules/xcode/node_modules/uuid
@expo/bunyan >=3.0.0
Depends on vulnerable versions of uuid
node_modules/@expo/bunyan
@expo/rudder-sdk-node *
Depends on vulnerable versions of @expo/bunyan
Depends on vulnerable versions of uuid
node_modules/@expo/rudder-sdk-node
xcode >=0.9.2
Depends on vulnerable versions of uuid
node_modules/xcode

xml2js <0.5.0
Severity: moderate
xml2js is vulnerable to prototype pollution - <https://github.com/advisories/GHSA-776f-qx25-q3cc>
fix available via `npm audit fix --force`
Will install expo@57.0.25, which is a breaking change
node_modules/xml2js

24 vulnerabilities (1 low, 9 moderate, 12 high, 2 critical)

6. Conclusão

O sistema possui hoje uma postura de segurança bastante sólida, comprovada pela ausência de falhas no código proprietário durante a análise SAST. Os apontamentos residuais ficaram inteiramente restritos a bibliotecas de desenvolvimento do ecossistema Mobile.

A escolha arquitetural de isolar a comunicação com a máquina de lançamento através de cabo serial local reduziu drasticamente nossa superfície de ataque. Atendemos integralmente aos requisitos da disciplina de Redes de Computadores e Cibersegurança ao aplicar o *hardening* da porta Serial no firmware (prevenindo *Buffer Overflows*) e implementar a diretiva *safe_stop*, garantindo a integridade tanto do equipamento físico quanto dos usuários finais.